🛡️ Seguridad de Gestión Pro Total

> **Nota honesta:** ningún software es "100 % inhackeable". Este documento describe las
>
> **medidas reales** aplicadas para reducir al máximo el riesgo y proteger los datos.

Medidas aplicadas

Licencias (anti-pirateo)

- **Firma ECDSA P-256**: las licencias se firman con una **clave privada** que solo tiene

el propietario. La app lleva solo la **clave pública** (no permite crear licencias).

- **Atadas al equipo** (deviceId): una clave solo vale en el equipo para el que se emite.
- **Detección de compartición**: si la misma clave se usa en varios equipos, se marca como

compartida, se **bloquea el equipo duplicado** y se avisa al propietario (modo nube).

- **Revocación**: el propietario puede revocar una clave; en modo nube bloquea al cliente.

Aplicación

- **Sin secretos en el cliente**: el código y las descargas solo contienen la clave

pública; la privada y los *keystores* **nunca** se publican (excluidos en `.gitignore`).

- **Content-Security-Policy** y `referrer-policy` en `index.html`: protegen frente a

clickjacking (`frame-ancestors 'none'`), inyección de objetos (`object-src 'none'`) y

secuestro de base (`base-uri 'self'`).

- **Sanitización** de texto en los paneles (escape de HTML) para evitar inyección.
- **HTTPS** en todas las comunicaciones (descargas, API, nube).
- **Funciona offline**: los datos del cliente pueden quedarse en su equipo.

Cadena de distribución

- Instaladores publicados desde **CI** (GitHub Actions) de forma reproducible.
- **Firma de código** (Windows/macOS) preparada: ver `docs/FIRMA-INSTALADORES.md`

(requiere certificados del propietario; elimina los avisos de "editor desconocido").

Backend en la nube (opcional)

- Google Apps Script ligado al correo del programa: recibe solicitudes, guarda claves y

comprobantes en **Google Drive** del propietario, detecta duplicados y avisa por email.

- La **clave privada de firma nunca se sube** a la nube.

Recomendaciones para reforzar más

- **Firmar los instaladores** con certificado (Windows EV / Apple Developer).
- **Activar el modo nube** para revocación/anti-compartición en tiempo real.
- Mantener **dependencias actualizadas** (`npm audit` periódico).
- Copia de seguridad regular del panel/licencias (botón Exportar) y de la clave privada.
- Contraseña fuerte del panel (⚙️ Configuración) y del backend (`PASS_ADMIN`).

Reporte de vulnerabilidades

Si detectas un fallo de seguridad, escribe a **kairigarcia.gestionprototal@gmail.com**.

No publiques el detalle hasta que se haya corregido (divulgación responsable).